



Tarea #6

Pentesting en la Práctica: Los Casos de Google y Uber

Profesor:

Dedaniel Urribarri

Elaborado por:

Luisdavid Colina V24766381

Fecha de solicitud: 02 de junio del 2026

Fecha de Entrega: 07 de junio 2026



Conceptos a Investigar

Pentesting: Definición, Fases y Metodología

El Pentesting, o Prueba de Penetración, es una metodología de seguridad ofensiva que consiste en simular un ataque real contra un sistema, red o aplicación, con autorización explícita del propietario, con el fin de identificar vulnerabilidades explotables antes de que un actor malicioso pueda aprovecharlas [1]. A diferencia del análisis de vulnerabilidades, que se limita a identificar y catalogar debilidades, el pentesting busca explotar activamente esas debilidades para evaluar el impacto real de una intrusión exitosa. Su objetivo final es proveer a la organización de información accionable para fortalecer su postura de seguridad.

La metodología estándar, definida por el EC-Council y adoptada en marcos como el PTES (Penetration Testing Execution Standard), se estructura en cinco fases: (1) Reconocimiento, donde se recopila información sobre el objetivo mediante técnicas pasivas y activas de OSINT; (2) Escaneo y enumeración, donde se identifican puertos, servicios y versiones vulnerables; (3) Explotación, donde se compromete el acceso no autorizado; (4) Post-explotación, donde se evalúa la profundidad del compromiso y la persistencia posible; y (5) Elaboración del informe, donde se documentan hallazgos, impacto y recomendaciones de remediación [1]. Dependiendo del nivel de información inicial otorgada al evaluador, el pentesting se clasifica como Caja Negra, Caja Gris o Caja Blanca.

Programas de Recompensa por Vulnerabilidades (Bug Bounty) como Extensión del Pentesting

Los programas de recompensa por vulnerabilidades, conocidos como Bug Bounty, constituyen una extensión institucionalizada del pentesting mediante la que las organizaciones invitan a investigadores de seguridad externos a buscar vulnerabilidades en sus sistemas a cambio de compensaciones económicas proporcionales a la criticidad de los hallazgos [2]. A diferencia de un contrato de pentesting tradicional —acotado en tiempo, alcance y equipo—, los programas Bug Bounty operan de forma continua y aprovechan la inteligencia colectiva de la comunidad global de investigadores de seguridad, permitiendo cubrir una superficie de ataque más amplia y detectar vulnerabilidades que escaparían a un equipo reducido.

La distinción técnica entre ambos enfoques es relevante: el pentesting formal sigue una metodología estructurada con inicio y fin definidos, garantías contractuales, y produce un informe ejecutivo y técnico completo; el Bug Bounty es un proceso continuo y descentralizado, cuya calidad varía según el alcance y las recompensas ofrecidas. Desde la perspectiva regulatoria, como la norma ISO/IEC 27001 y los controles del NIST CSF, ambos



enfoques son complementarios: el primero aporta profundidad y el segundo aporta cobertura y continuidad [2].

Caso Google: El Vulnerability Reward Program (VRP) como Modelo de Pentesting Continuo

El Vulnerability Reward Program (VRP) de Google, lanzado en 2010, representa uno de los programas de Bug Bounty más maduros de la industria. En 2025, año que coincidió con su 15.º aniversario, Google alcanzó un récord histórico al otorgar más de 17 millones de dólares en recompensas a más de 700 investigadores de todo el mundo, un incremento superior al 40% respecto a los 12 millones pagados en 2024 [3]. Desde su creación, el programa ha distribuido más de 81,6 millones de dólares acumulados, consolidándose como el estándar de referencia del sector.

Entre los hitos técnicos más relevantes del VRP en 2025 destaca el lanzamiento de un programa dedicado exclusivamente a vulnerabilidades en sistemas de Inteligencia Artificial, reflejando la expansión de la superficie de ataque hacia modelos de aprendizaje automático. Asimismo, el Chrome VRP incorporó categorías específicas para fallos en componentes de IA, y se creó un programa de parches para OSV-SCALIBR, la herramienta de código abierto de Google para detectar vulnerabilidades en dependencias de software [3]. En 2026, Google elevó las recompensas máximas del programa Android hasta 1,5 millones de dólares para exploits de cadena completa sin interacción del usuario sobre el chip de seguridad Titan M2 de los Pixel, demostrando que el modelo de pentesting continuo escala junto con la criticidad de los activos protegidos [4].

Caso Uber 2022: La Brecha que Expuso las Limitaciones del Factor Humano

El 15 de septiembre de 2022, Uber sufrió una de las brechas de seguridad más analizadas de la década, no por su sofisticación técnica, sino precisamente por la ausencia de ella. Un atacante de 18 años, presuntamente afiliado al grupo Lapsus\$, comprometió la red interna de Uber mediante una cadena de ingeniería social [5]. El vector inicial consistió en la compra de credenciales de un contratista externo en el mercado negro, seguida de una campaña de saturación de MFA (MFA Bombing): el atacante envió notificaciones push de autenticación repetidamente hasta que el contratista, agotado, aprobó una de ellas. Para acelerar el proceso, el atacante se hizo pasar por personal de IT de Uber vía WhatsApp, alegando que las notificaciones cesarían al aceptar la solicitud [5].

Con acceso a la VPN corporativa, el atacante realizó reconocimiento lateral y localizó scripts de PowerShell en recursos compartidos de red que contenían credenciales administrativas en texto plano [6]. Esto le permitió escalar privilegios y comprometer herramientas críticas como G-Suite, Slack y los sistemas de facturación de Uber, además de reconfigurar el sistema OpenDNS interno. El incidente expuso además los reportes de



vulnerabilidades pendientes del propio programa de Bug Bounty de Uber. La brecha demostró que sin controles de autenticación resistentes al phishing como claves FIDO2, y sin una gestión rigurosa de credenciales privilegiadas (PAM), ningún programa de Bug Bounty puede compensar las debilidades del factor humano [5], [6].

Lecciones Comparadas: Google vs. Uber y el Rol del Pentesting en la Madurez de Seguridad

La comparación entre los casos de Google y Uber ilustra los dos extremos del espectro en la integración del pentesting como práctica de seguridad. Google representa el modelo de madurez máxima: un programa estructurado, con reglas claras, recompensas escaladas según criticidad y capacidad de evolucionar junto con las amenazas emergentes, como la IA. La inversión sostenida de más de 81,6 millones de dólares en 15 años refleja el reconocimiento de que la seguridad proactiva es más rentable que la respuesta reactiva [3].

El caso Uber, por el contrario, expone que la existencia de un programa de Bug Bounty no previene brechas cuando la vulnerabilidad explotada es conductual y no técnica. Este contraste demuestra que el pentesting efectivo debe incluir pruebas de ingeniería social (red team) y simulaciones de phishing dirigido junto con las pruebas de infraestructura convencionales. Las lecciones del caso Uber —implementar MFA resistente al phishing (FIDO2), eliminar credenciales en texto plano, aplicar gestión de acceso privilegiado (PAM) y extender la concienciación de seguridad a contratistas— constituyen hoy recomendaciones estándar en marcos como el NIST SP 800-115 y los controles de CIS v8 [1], [5].



Conclusiones

El análisis del pentesting a través de los casos reales de Google y Uber permite extraer conclusiones que articulan la teoría con la práctica de la seguridad ofensiva. Se concluye que:

- Los programas de Bug Bounty, como el VRP de Google con más de 81,6 millones de dólares distribuidos en 15 años, representan la institucionalización del pentesting continuo y demuestran que la inversión en seguridad proactiva es consistentemente más rentable que la gestión reactiva de incidentes.
- El caso Uber evidencia que el pentesting técnico es insuficiente sin pruebas del vector humano: la ingeniería social, el MFA Bombing y la gestión deficiente de credenciales privilegiadas constituyeron el camino de menor resistencia hacia el compromiso total de la red, sin explotar ninguna vulnerabilidad técnica.
- La madurez de un programa de pentesting no se mide por su presupuesto, sino por su cobertura: debe abarcar infraestructura, aplicaciones, ingeniería social, cadena de suministro de terceros y, en el contexto actual, superficies de ataque emergentes como los sistemas de Inteligencia Artificial.
- La combinación de pentesting formal periódico, programas de Bug Bounty continuos y simulaciones de ingeniería social conforma el ciclo de verificación de seguridad más robusto disponible, alineándose con los principios de defensa en profundidad propuestos por ISO/IEC 27001 y los controles CIS v8.



Referencias

- [1] EC-Council, "Certified Ethical Hacker (CEH) Version 12 Study Guide," Wiley, 2023.
/ NIST, "Technical Guide to Information Security Testing and Assessment," NIST SP 800-115, National Institute of Standards and Technology, 2008.
- [2] Google, "Bug Bounty and Vulnerability Reward Programs," Google Partner Security Documentation, 2025. [En línea]. Disponible: https://partner-security.withgoogle.com/docs/annex/bug_bounty_vrp.html
- [3] Google Security Blog, "VRP 2025 Year in Review," Google, marzo 2026. [En línea]. Disponible: <https://security.googleblog.com/2026/03/vrp-2025-year-in-review.html>
- [4] Goodin, D., "Google Now Offers Up to \$1.5 Million for Some Android Exploits," BleepingComputer, mayo 2026. [En línea]. Disponible: <https://www.bleepingcomputer.com/news/security/google-now-offers-up-to-15-million-for-some-android-exploits/>
- [5] Egress Software Technologies, "Uber Breach Proves Power of Social Engineering," Egress Blog, septiembre 2022. [En línea]. Disponible: <https://www.egress.com/blog/phishing/uber-breach-social-engineering>
- [6] GitGuardian, "Uber Breach 2022: Everything You Need to Know," GitGuardian Blog, 2022. [En línea]. Disponible: <https://blog.gitguardian.com/uber-breach-2022/>